

Planejamento do Projeto da Disciplina

Matheus Grupp da Rosa, André Jacopetti Ruivo Junior

Cibersegurança – Pontifícia Universidade Católica do Paraná (PUCPR) – Curitiba – PR
- Brasil

1. Introdução

Este relatório descreve o planejamento e a estrutura da aplicação **SuperDevSecOps**, cujo código está disponível no repositório do GitHub:

<https://github.com/MatheusGrupp/SuperDevSecOps>

O objetivo é demonstrar a aplicação dos conceitos DevSecOps aplicados em um ambiente real, com ênfase em arquitetura de microsserviços, automação de testes, integração contínua e segurança integrada durante o desenvolvimento. O presente documento segue o template da SBC e contempla todas as seções solicitadas.

2. Descrição Geral do Sistema

A **SuperDevSecOps** é uma aplicação web modular concebida para gerenciar funcionalidades críticas de forma centralizada e segura. O sistema foi desenvolvido adotando os princípios do DevSecOps, integrando desenvolvimento, segurança e operações em um único fluxo contínuo. A solução se estrutura em microsserviços containerizados, permitindo isolamento de responsabilidades e a facilidade de escalabilidade e manutenção.

Os principais componentes da aplicação são:

Aplicação Web (Frontend): Responsável por renderizar a interface do usuário e capturar interações via HTML/CSS.

API Gateway: Centraliza e roteia as requisições para os serviços internos, aplicando políticas de autenticação e autorização.

Serviço de Autenticação: Garante o gerenciamento seguro de logins, cadastros e sessões, comunicando-se com o banco de dados dedicado a usuários.

Serviço de Gerenciamento de Tarefas: Responsável pelo CRUD (criação, leitura, atualização e exclusão) de tarefas e atividades, operando sobre seu respectivo banco de dados.

Banco de Dados: Estrutura a persistência de dados, segregando informações de usuários e tarefas para otimização de performance e segurança.

A comunicação entre os módulos é realizada por meio de APIs, e a infraestrutura foi preparada para ser implantada via containers, possibilitando deploys independentes e escalabilidade horizontal.

3. Descrição dos Usuários

O sistema foi desenvolvido para atender a dois perfis principais:

Cliente:

Usuário final que acessa a aplicação para gerenciar suas tarefas, visualizar notificações e realizar operações básicas, como criar e editar atividades. A interface é otimizada para proporcionar uma boa experiência, independentemente do dispositivo utilizado.

Administrador:

Responsável pela gestão do ambiente, controle de usuários, monitoramento do sistema e implementação de novas funcionalidades. Este perfil possui privilégios maiores e ferramentas de auditoria e gerenciamento, garantindo que a operação seja realizada de forma segura e eficiente.

4. Requisitos Funcionais

Para assegurar o funcionamento integral da aplicação, foram definidos, no mínimo, 20 requisitos funcionais. Abaixo, alguns exemplos essenciais:

[RF01]	Cadastro de Usuário
Descrição	Permitir a criação de novas contas com validação dos dados
Prioridade	Alta

[RF02]	Autenticação Segura
Descrição	Realizar login e logout utilizando mecanismos robustos de verificação
Prioridade	Alta

[RF03]	Recuperação de Senha
Descrição	Possibilitar a redefinição de senha mediante procedimento seguro
Prioridade	Alta

[RF04]	Gerenciamento de Perfil
Descrição	Permitir aos usuários alterarem seus dados cadastrais e configurações pessoais
Prioridade	Média

[RF05]	Criação de Tarefas
Descrição	Fornecer funcionalidades para cadastrar, editar e remover tarefas
Prioridade	Alta

[RF06]	Visualização de Tarefas
Descrição	Disponibilizar listagem organizada e filtrada das tarefas criadas
Prioridade	Alta

[RF07]	Registro de Logs
Descrição	Armazenar registros detalhados de ações críticas para auditoria
Prioridade	Média

[RF08]	Sistema de Notificações
Descrição	Implementar alertas em tempo real sobre eventos relevantes
Prioridade	Média

[RF09]	Integração por API DJANGO
Descrição	Garantir comunicação padronizada e segura entre os microserviços
Prioridade	Alta

[RF10]	Upload e Gerenciamento de Arquivos
Descrição	Permitir a anexação e o gerenciamento de documentos relacionados às atividades
Prioridade	Média

[RF11]	Geração de Relatórios
Descrição	Produzir relatórios de desempenho e auditoria em formatos padronizados
Prioridade	Média

[RF12]	Dashboard de Monitoramento
Descrição	Realizar login e logout utilizando mecanismos robustos de verificação
Prioridade	Alta

[RF13]	Validação de Dados
Descrição	Implementar verificações para evitar inserção de dados inválidos
Prioridade	Alta

[RF14]	Interface de Administração
Descrição	Oferecer ferramentas para gerenciamento e configuração do ambiente pela equipe administrativa
Prioridade	Alta

[RF15]	Roteamento via API Gateway
Descrição	Centralizar a comunicação entre os serviços internos
Prioridade	Alta

[RF16]	Gerenciamento de Sessões
Descrição	Controlar de forma segura as sessões ativas dos usuários
Prioridade	Alta

[RF17]	Auditoria de Ações Críticas
Descrição	Registrar ações que possam afetar a segurança ou integridade do sistema
Prioridade	Alta

[RF18]	Backup e Recuperação
Descrição	Implementar processos de backup automático e recuperação de dados
Prioridade	Alta

[RF19]	Responsividade da Interface
Descrição	Adaptar a interface para diferentes tamanhos de tela e dispositivos
Prioridade	Média

[RF20]	Suporte a Multilíngue
Descrição	Permitir que a aplicação opere em diversos idiomas
Prioridade	Média

5. Requisitos Não Funcionais

A robustez e a eficácia da aplicação dependem de adequados requisitos não funcionais, que estabelecem limites e condições para o sistema operar com qualidade:

[RF01]	Performance
Categoria	Desempenho
Descrição	Respostas às requisições devem ser entregues em, no máximo, 2 segundos sob condições normais de uso
Prioridade	Alta

[RF02]	Disponibilidade
Categoria	Confiabilidade
Descrição	O sistema deve atingir uma disponibilidade de 99,9%, minimizando períodos de inatividade
Prioridade	Alta

[RF03]	Confiabilidade e Redundância
Categoria	Confiabilidade
Descrição	Adotar mecanismos de backup e redundância dos serviços e bancos de dados para garantir a continuidade do serviço
Prioridade	Alta

[RF04]	Segurança
Categoria	Segurança
Descrição	Implementar protocolos de criptografia (HTTPS, TLS), autenticação multifator e monitoramento contínuo para proteção contra ameaças.
Prioridade	Alta

[RF05]	Escalabilidade
Categoria	Escalabilidade
Descrição	Projetar a arquitetura para suportar expansões horizontais e verticais conforme a demanda crescente do sistema.
Prioridade	Média

[RF06]	Manutenibilidade
Categoria	Manutenibilidade
Descrição	Desenvolver código modular, documentado e aderente a padrões que facilitem futuras manutenções e atualizações.
Prioridade	Média

[RF07]	Usabilidade
Categoria	Usabilidade
Descrição	Garantir uma interface intuitiva e de fácil navegação, facilitando o uso mesmo para usuários com menor conhecimento tecnológico.
Prioridade	Média

6. Diagrama da Arquitetura baseada em microsserviços

Frontend:

Interface de usuário: Exibe páginas, captura interações e envia requisições HTTP ao gateway.

API Gateway:

Ponto de entrada único: Roteia chamadas para serviços internos e aplica políticas de segurança (autenticação, autorização).

Serviço de Autenticação:

Gerencia autenticação e sessões: Valida credenciais, emite tokens e expõe endpoints de login/cadastro.

DB de Autenticação:

Armazena dados de usuários e sessões de forma isolada, garantindo integridade e segurança das credenciais.

Serviço de Tarefa:

Lógica de negócio para tarefas: implementa operações CRUD (criação, leitura, atualização, exclusão) sobre recursos de atividade.

DB de Tarefa:

Persiste dados de tarefas e metadados associados, mantendo-os segregados dos dados de usuários.

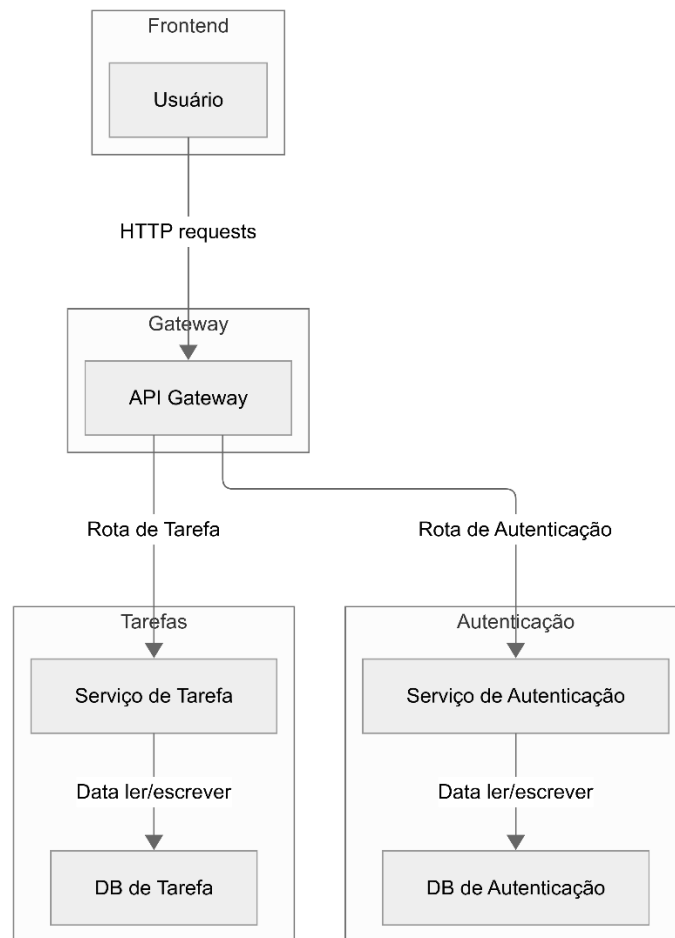


Figure 1. Diagrama de Microserviços

7. Diagrama de Fluxo de Dados

Usuário: Entidade externa que interage com o sistema através da interface web.

Processo de Autenticação: Responsável por validar as credenciais dos usuários e gerenciar sessões.

Processo de Gerenciamento de Tarefas: Lida com as operações relacionadas às tarefas dos usuários.

Banco de Dados de Usuários: Armazena informações dos usuários, como credenciais e dados de perfil.

Banco de Dados de Tarefas: Contém os dados das tarefas criadas pelos usuários.

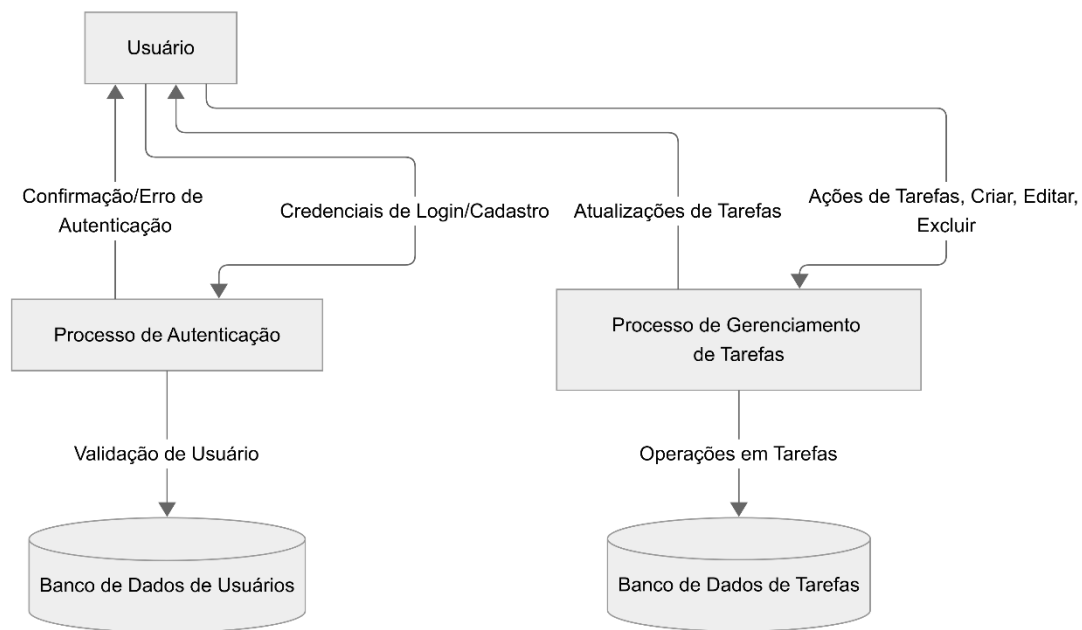


Figure 2. Diagrama de Fluxo de Dados

8. Modelo do Adversário usando STRIDE

A análise de ameaças utilizando o modelo STRIDE é essencial para identificar os riscos e definir mitigações. A seguir, uma avaliação direta dos principais aspectos:

Spoofing (Falsificação):

Risco: Tentativa de um invasor se passar por outro usuário.

Mitigação: Emprego de autenticação robusta com MFA e emissão de tokens seguros.

Tampering (Alteração):

Risco: Interceptação e modificação de dados durante a comunicação entre serviços.

Mitigação: Uso obrigatório de criptografia (HTTPS/TLS) e validação de integridade dos dados.

Repudiation (Repúdio):

Risco: Negativa do usuário em ter realizado uma ação, comprometendo a auditoria.

Mitigação: Implementação de logs detalhados com marcação temporal e identificação do autor de cada ação.

Information Disclosure (Divulgação de Informações):

Risco: Exposição não autorizada de dados confidenciais.

Mitigação: Aplicação rigorosa de controles de acesso, criptografia dos dados sensíveis e segregação lógica dos ambientes.

Denial of Service (Negação de Serviço):

Risco: Sobrecarga do sistema com volume excessivo de requisições, tornando-o indisponível.

Mitigação: Adoção de balanceadores de carga, escalabilidade automática e monitoramento contínuo para identificar e mitigar anomalias.

Elevation of Privilege (Elevação de Privilégios):

Risco: Exploração de vulnerabilidades que permitam a um usuário comum executar ações restritas.

Mitigação: Implementação de controle de acesso baseado em funções (RBAC) com validações rigorosas e segmentação dos privilégios.

9. Etapas Futuras

Considerando o cenário atual do repositório e as necessidades de evolução do sistema, propõe-se o seguinte para as próximas fases do projeto:

9.1. Integração com Infraestrutura de Nuvem e Orquestração de Contêineres:

Migrar a aplicação para provedores de nuvem (AWS, Azure ou Google Cloud) e utilizar plataformas de orquestração, como o Kubernetes, para aprimorar a escalabilidade e resiliência do ambiente. Essa ação permitirá atualizações com zero downtime e melhor gerenciamento dos recursos.

9.2. Incorporação de Análise de Inteligência Artificial para Monitoramento:

Implementar módulos de machine learning capazes de identificar padrões incomuns nos logs e no tráfego da aplicação, possibilitando a detecção precoce de ataques e a automação de respostas a incidentes de segurança.

9.3. Aperfeiçoamento do Pipeline DevSecOps:

Fortalecer a integração contínua e a entrega contínua (CI/CD) com a inclusão de testes de segurança automatizados – como análise estática de código, pentests e verificações de vulnerabilidades em tempo real –, garantindo que todas as novas implementações mantenham os padrões de segurança definidos.

References:

Sociedade Brasileira de Computação (SBC):

SBC. Template de Artigos Científicos. Disponível em:
<https://www.sbc.org.br/publicacoes/modelos> (Acesso em 2025).

Sommerville, I. (2007):

Sommerville, I. Software Engineering (8ª ed.). Addison-Wesley.